National University of Computer and Emerging Sciences

FAST – NUCES | Islamabad Campus

CYBER THREAT INTELLIGENCE REPORT

Analysis of Stuxnet Using STIX 2.1

ISO/IEC 27001 | NIST SP 800-150 Aligned

Student Name	Sarmad Farooq
Roll Number	25i-7722
Instructor	Sir Zafar Iqbal
Subject	Advanced Network Security (ANS)
Activity	Activity 1 – Cyber Threat Intelligence using STIX
Date	April 2025
Classification	Academic Use Only – Confidential

Table of Contents

Table of Contents ..... **Error! Bookmark not defined.**
1. Executive Summary 4
2. Introduction 5
  2.1 Background 5
  2.2 Objectives 5
  2.3 Standards and Frameworks Applied 5
3. Step 1 – Attack Selection and Source Research 6
  3.1 Attack Overview 6
  3.2 Source 1: MITRE ATT&CK (S0603) 6
  3.3 Source 2: NVD/NIST – CVE Vulnerability Database 7
    3.3.1 CVE-2010-2568 – Windows Shell LNK Shortcut (CVSS 9.3 Critical) 7
    3.3.2 CVE-2010-2772 – Siemens WinCC Hard-Coded Password (CVSS 7.2 High) 7
    3.3.3 CVE-2010-2729 – Windows Print Spooler RCE (CVSS 9.3 Critical) 7
    3.3.4 CVE-2010-3338 – Windows Task Scheduler Privilege Escalation (CVSS 7.2 High) 8
  3.4 Source 3: Symantec W32.Stuxnet Dossier v1.4 8
    3.4.1 Malware File Artifacts 9
    3.4.2 Registry Persistence Keys 9
    3.4.3 PLC Payload – OB1/OB35 Code Injection 10
    3.4.4 Stolen Digital Certificates 10
  3.5 Source 4: Kaspersky Securelist – Actor Attribution and Code Families 10
    3.5.1 The GOSSIP GIRL Collaboration 11
    3.5.2 Global Infection Distribution 12
  3.6 Source 5: CISA ICS-CERT Advisory ICSA-10-272-01 12
    3.6.1 Affected Siemens Product Versions 13
  3.7 Source 6: Academic Literature 13
4. Step 2 – Threat Intelligence Extraction 14
5. Step 3 – STIX 2.1 Object Mapping 15
  5.1 STIX Object Registry Overview 15
  5.2 Threat Actor SDO 15
  5.3 Malware SDO 16
  5.4 Attack Pattern SDOs (TTPs) 16
  5.5 Vulnerability SDOs 18
  5.6 Indicator SDOs (IOCs) 19
  5.7 Course of Action SDOs 19
6. STIX 2.1 Relationship Objects (SROs) 22
7. Step 4 – STIX JSON Bundle and Visualization 24
  7.1 STIX 2.1 JSON Bundle 24

7.2 STIX Relationship Graph Visualization 24
8. Conclusions 26
9. References 27
Appendix A – Research Collection Sheet 28

1. Executive Summary

This report presents a structured Cyber Threat Intelligence (CTI) analysis of the Stuxnet worm (MITRE Software ID: S0603) widely regarded as the world's first confirmed cyber-weapon deployed against critical industrial infrastructure. The analysis follows a systematic four-step methodology: threat research, intelligence extraction, STIX 2.1 object mapping, and structured data visualization.

Stuxnet was discovered in June 2010 and targeted the Natanz Uranium Enrichment Facility in Iran, operated by the Atomic Energy Organization of Iran (AEOI). The malware was attributed to the Equation Group believed to be a joint operation between the United States National Security Agency (NSA/TAO) and Israeli Intelligence Unit 8200 under the codename Operation Olympic Games [1].

The malware exploited four simultaneous zero-day vulnerabilities, used stolen digital certificates, and deployed the world's first Programmable Logic Controller (PLC) rootkit, ultimately destroying approximately 1,000 uranium enrichment centrifuges and delaying Iran's nuclear program by an estimated two years [2].

This report maps all extracted intelligence to STIX 2.1 Domain Objects (SDOs) and Structured Relationship Objects (SROs), producing a comprehensive, machine-readable threat intelligence bundle aligned with ISO/IEC 27001 and NIST SP 800-150 standards for threat intelligence sharing [3].

42 Total STIX Objects	8 Object Types	18 Relationships	4 Zero-Days Exploited
5 Attack Patterns (TTPs)	7 Indicators (IOCs)	6 Courses of Action	~100K+ Systems Infected

Table 1: Executive Summary Statistics

2. Introduction

2.1 Background

Modern cyber threats against critical infrastructure represent one of the most significant challenges in national security and industrial safety. The emergence of sophisticated state-sponsored malware capable of causing physical destruction marks a fundamental shift in the nature of cyber warfare. Stuxnet, discovered in June 2010, was the first publicly documented example of such a weapon [4].

Cyber Threat Intelligence (CTI) is the practice of collecting, analyzing, and structuring information about cyber threats in a way that enables organizations to understand, detect, and defend against malicious actors. The Structured Threat Information eXpression (STIX) 2.1 framework, maintained by OASIS, provides a standardized language for representing this intelligence in machine-readable format, enabling automated sharing and processing across security tools and organizations [5].

2.2 Objectives

- Research and document the Stuxnet attack using credible, authoritative sources including MITRE ATT&CK, NVD/NIST, Symantec, Kaspersky, and CISA
- Extract structured Cyber Threat Intelligence answering the core questions: Who, What, How, Why, and When
- Map all intelligence to formal STIX 2.1 Domain Objects (SDOs) and Relationship Objects (SROs)
- Create a complete STIX 2.1 JSON bundle for threat intelligence sharing
- Visualize the STIX relationship graph using the STIX Viz tool
- Propose actionable mitigation recommendations aligned with CISA guidelines

2.3 Standards and Frameworks Applied

Standard / Framework	Version / Reference	Application in This Report
STIX	STIX 2.1 (OASIS)	Threat intelligence structuring and SDO/SRO mapping
MITRE ATT&CK	Enterprise + ICS Matrix	TTP identification (T1091, T1014, T1553, T1195)
NVD / NIST	NIST SP 800-150	CVE documentation, CVSS scoring, CTI sharing guidelines
ISO/IEC 27001	ISO/IEC 27001:2022	Information security management context
CISA ICS-CERT	ICSA-10-272-01	Official mitigation guidance for ICS/SCADA environments

Table 2: Standards and Frameworks Applied

3. Step 1 – Attack Selection and Source Research

3.1 Attack Overview

Stuxnet (W32.Stuxnet) was selected for this CTI analysis due to its unparalleled significance in the history of cyber warfare. It was the first malware specifically designed to cause physical destruction by targeting industrial control systems representing a convergence of cyber operations and kinetic warfare [1].

Field	Details
Attack Name	Stuxnet (W32.Stuxnet)
First Seen	June 17, 2010 – Discovered by VirusBlokAda / Sergey Ulasen (Belarus)
Threat Actor	Equation Group (NSA/TAO + Israeli Unit 8200)
Codename	Operation Olympic Games / GOSSIP GIRL
Motivation	Sabotage Iran's uranium enrichment program – destroy Natanz IR-1 centrifuges
Primary Target	Natanz Uranium Enrichment Facility, AEOI, Iran
Target System	Siemens S7-315 / S7-417 PLCs via SIMATIC WinCC and STEP 7
Malware Type	Worm + Windows Rootkit + PLC Cyberweapon
Damage	~1,000 centrifuges physically destroyed; Iran nuclear program delayed ~2 years

Table 3: Stuxnet Attack Quick Reference

3.2 Source 1: MITRE ATT&CK (S0603)

MITRE ATT&CK is the industry-standard framework for documenting adversary behaviors. Stuxnet is catalogued as Software entry S0603 and maps to several key techniques in both the Enterprise and ICS matrices [6].

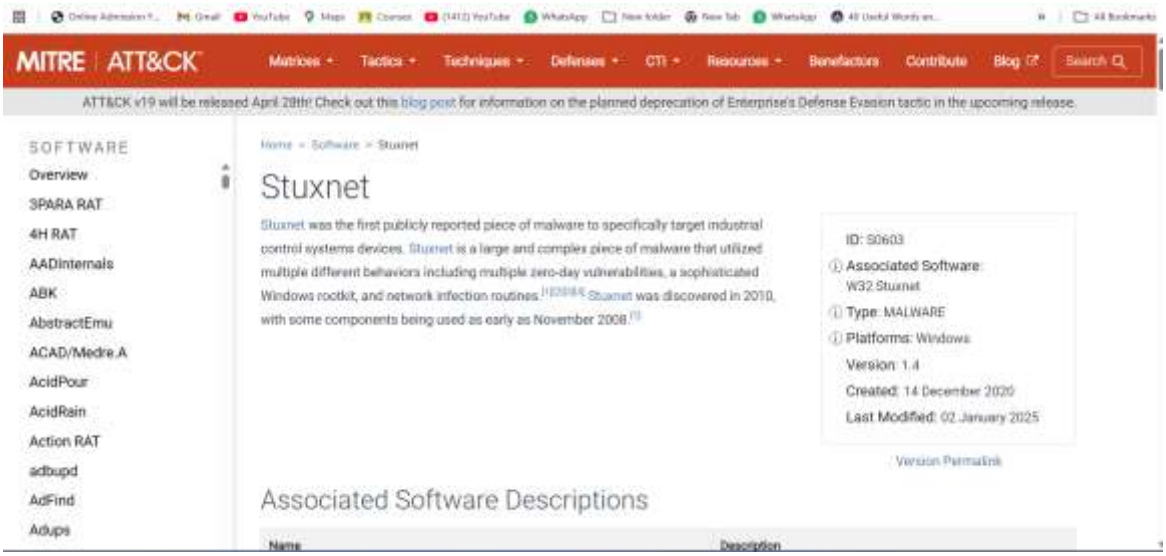

Figure 1: Stuxnet entry on MITRE ATT&CK (S0603) – Software profile

ATT&CK Field	Stuxnet Values
Software ID	S0603
Type	Malware
Techniques Used	T1091 (USB Replication), T1014 (Rootkit), T1553 (Code Signing), T1195 (Supply Chain)
Platforms Targeted	Windows XP–7, ICS/SCADA (Siemens WinCC, STEP 7, S7 PLCs)
Groups (Actors)	Equation Group

Table 4: Stuxnet ATT&CK Profile

3.3 Source 2: NVD/NIST – CVE Vulnerability Database

The National Vulnerability Database (NVD), maintained by NIST, documents the four zero-day vulnerabilities that Stuxnet simultaneously exploited an unprecedented achievement at the time of discovery. Each CVE is documented with CVSS scoring to quantify severity [7].

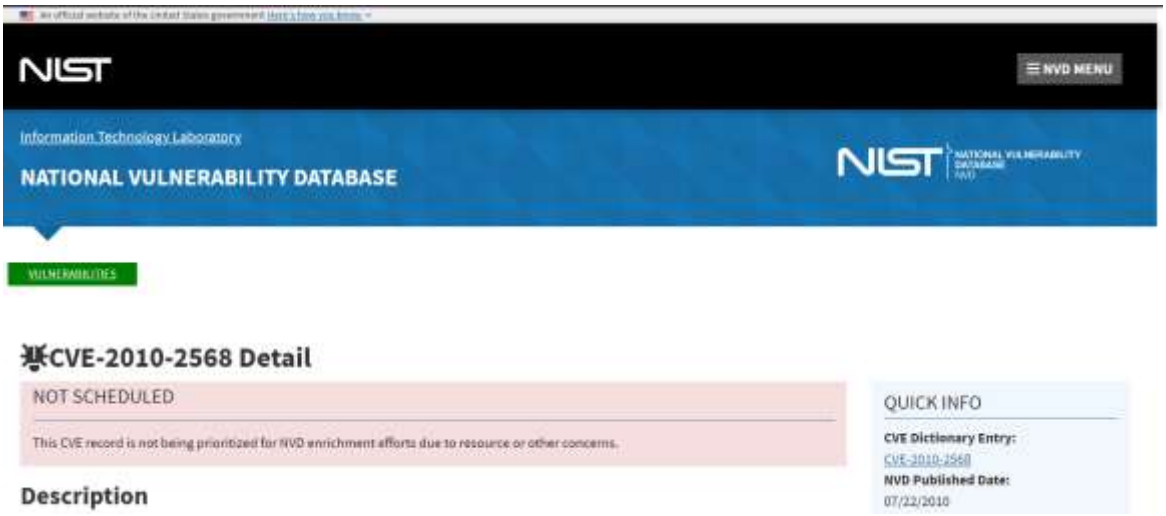

Figure 2: NVD/NIST CVE documentation for Stuxnet vulnerabilities

3.3.1 CVE-2010-2568 – Windows Shell LNK Shortcut (CVSS 9.3 Critical)

Windows Explorer automatically displays icons for shortcut (.LNK) files. Stuxnet placed a malicious .LNK file on a USB drive. When the USB was inserted and Windows attempted to render the icon, the malicious code executed automatically without any user click required. This was the primary mechanism by which Stuxnet crossed the air-gap into the Natanz facility [7].

3.3.2 CVE-2010-2772 – Siemens WinCC Hard-Coded Password (CVSS 7.2 High)

Siemens WinCC and PCS 7 SCADA systems used a hard-coded password for their back-end SQL database. This design flaw, classified as CWE-255 (Credentials Management), allowed Stuxnet to log directly into the Siemens SQL database on infected machines and gain access to PLC programming data without requiring any additional authentication [7].

3.3.3 CVE-2010-2729 – Windows Print Spooler RCE (CVSS 9.3 Critical)

The Print Spooler service in Windows did not properly validate spooler access permissions, enabling remote attackers to create files in a system directory and execute arbitrary code by sending a crafted print request over RPC. With an EPSS score of 97.08%, this vulnerability was classified as extremely likely to be exploited in the wild. Stuxnet used this vector to spread laterally across local area networks without requiring USB drives [7].

3.3.4 CVE-2010-3338 – Windows Task Scheduler Privilege Escalation (CVSS 7.2 High)

The Windows Task Scheduler used only a CRC32 checksum to validate task files against tampering. By creating a CRC32 collision through file modification, an attacker could execute arbitrary commands with SYSTEM privileges the highest privilege level on Windows. Stuxnet exploited this to escalate from regular user access to full system control [7].

CVE ID	Vulnerability	CVSS	Type	MS Bulletin	Target
CVE-2010-2568	Windows Shell LNK	**9.3**	Remote RCE	MS10-046	All Windows
CVE-2010-2772	Siemens WinCC Hardcoded Pwd	**7.2**	Local PrivEsc	Siemens Patch	WinCC / PCS7
CVE-2010-2729	Print Spooler RCE	**9.3**	Remote RCE	MS10-061	All Windows
CVE-2010-3338	Task Scheduler LPE	**7.2**	Local PrivEsc	MS10-092	Vista / 7

Table 5: Stuxnet CVE Summary Comparison

3.4 Source 3: Symantec W32.Stuxnet Dossier v1.4

The Symantec (now Broadcom) technical dossier authored by Falliere, Murchu, and Chien (2011) remains the most comprehensive 69-page technical analysis of Stuxnet. It documents all file artifacts, registry keys, process injections, and PLC payload mechanics [2].

Figure 3: Stuxnet malware file artifacts documented in Symantec Dossier v1.4

Figure 4: Symantec threat encyclopedia entry for W32.Stuxnet

3.4.1 Malware File Artifacts

When a removable drive infected with Stuxnet was connected to a computer, the worm copied itself as specific files to both the USB drive and the Windows system directory. These file artifacts serve as critical Indicators of Compromise (IOCs) [2].

File Name	Location	Purpose
~WTR4132.tmp	USB Drive Root	Main dropper DLL – primary payload loader
~WTR4141.tmp	USB Drive Root	User-mode rootkit – hides Stuxnet files on USB flash memory
mrxcls.sys	C:\Windows\System32\Drivers\	Kernel rootkit – injects code into running processes
mrxnet.sys	C:\Windows\System32\Drivers\	NDIS filter – hides malware files on disk
oem7a.PNF	C:\Windows\inf\	Encrypted main DLL payload
mdmcpq3.PNF	C:\Windows\inf\	Encrypted data file
mdmeric3.PNF	C:\Windows\inf\	Encrypted configuration data
oem6c.PNF	C:\Windows\inf\	Encrypted secondary component

Table 6: Stuxnet File Artifacts (IOCs)

3.4.2 Registry Persistence Keys

Stuxnet achieved persistence through Windows registry modifications that caused its kernel-mode drivers to load automatically at every system startup. The malware ran as hidden services named MRXCLS and MRXNET.

- HKLM\SYSTEM\CurrentControlSet\Services\MRxCls – Starts mrxcls.sys (kernel injection driver) at boot
- HKLM\SYSTEM\CurrentControlSet\Services\MRxNet – Starts mrxnet.sys (file-hiding NDIS driver) at boot

The malicious kernel code also injected itself into system-critical processes including svchost.exe, services.exe, and lsass.exe. After injection, their module lists contained libraries with names following the pattern kernel32.dll.aslr.<random_hex>, designed to appear legitimate [2].

3.4.3 PLC Payload – OB1/OB35 Code Injection

Stuxnet contained the world's first PLC rootkit. Its ultimate objective was to reprogram the Siemens S7-315 and S7-417 PLCs controlling the IR-1 centrifuges at Natanz. The attack worked by injecting malicious code blocks into two specific PLC Organizational Blocks [2].

- OB1: Main PLC program block, executed every cycle. Stuxnet injected here to control centrifuge rotation speed, alternating between dangerously high (1,410 Hz) and dangerously low (2 Hz) frequencies, compared to the normal operating frequency of approximately 1,000 Hz
- OB35: Watchdog and interrupt handler block. Stuxnet hijacked this block to intercept monitoring signals and report false normal readings to SCADA operators, preventing detection of the sabotage

The result was that operators watching their SCADA screens saw perfectly normal centrifuge readings while the centrifuges were physically spinning themselves to destruction.

3.4.4 Stolen Digital Certificates

To bypass Windows Vista and Windows 7 requirements for signed kernel-mode drivers, Stuxnet's authors stole valid code-signing certificates from two legitimate Taiwanese companies both headquartered within 5 minutes of each other in Hsinchu Science Park, Taiwan suggesting targeted physical or cyber compromise of both organizations [2].

Certificate	Company	Purpose	Status
Cert #1	Realtek Semiconductor Corp	Signs mrxcls.sys driver	Revoked – VeriSign
Cert #2	JMicron Technology Corp	Signs mrxnet.sys driver	Revoked – VeriSign

Table 7: Stolen Digital Certificates Used by Stuxnet

3.5 Source 4: Kaspersky Securelist – Actor Attribution and Code Families

Kaspersky Lab's research, particularly their 2015 Equation Group report, provided critical attribution evidence linking Stuxnet to the broader Equation Group threat actor ecosystem. Their research revealed shared zero-day exploits between Stuxnet and an earlier Equation Group tool called Fanny.bmp, which used two of Stuxnet's zero-days as early as 2008 two years before Stuxnet's discovery [8].

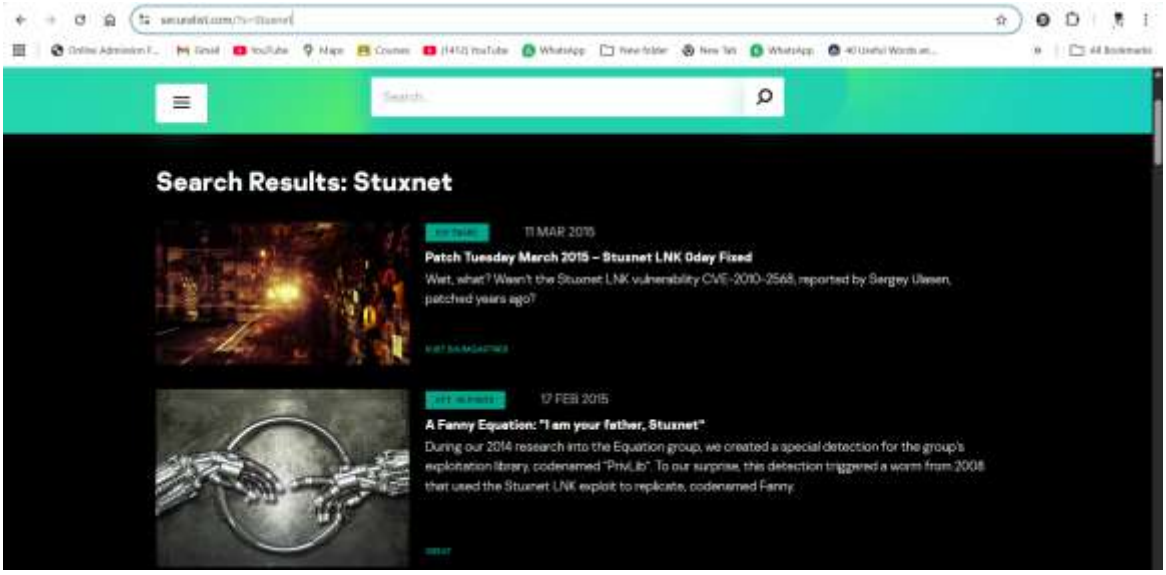

Figure 5: Kaspersky Equation Group attribution evidence linking Stuxnet to NSA/TAO

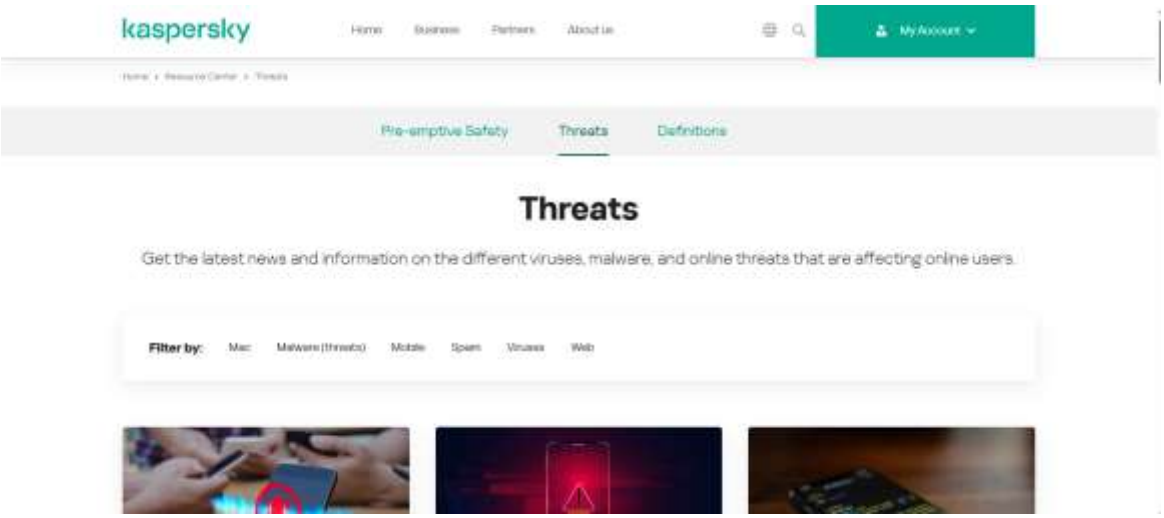

Figure 6: Code similarity analysis between Stuxnet, Flame, Duqu, and Gauss malware families

3.5.1 The GOSSIP GIRL Collaboration

In 2019, Chronicle researchers presented findings indicating that at least four distinct threat actor malware platforms collaborated in developing different versions of Stuxnet. This collaboration was referred to as GOSSIP GIRL, encompassing the Equation Group, Flame, Duqu, and Flowershop threat actors [8].

Malware	Relationship to Stuxnet	Year Identified
Duqu	Shares Tilded platform source code with Stuxnet	2011
Flame	Shares USB propagation module with nearly identical code	2012
Gauss	Same Command-and-Control (C2) infrastructure as Flame/Stuxnet	2012
Fanny	Used the same zero-day exploits as Stuxnet – two years earlier (2008)	2008

Table 8: GOSSIP GIRL Malware Family Code Similarities

3.5.2 Global Infection Distribution

Despite being precision-targeted at the Natanz facility, Stuxnet spread globally due to its aggressive USB and network propagation mechanisms. Symantec reported in August 2010 that approximately 60% of all infected computers worldwide were located in Iran [2][8].

Country	Infection %	Reason for Infection
Iran	**~60%**	Primary target – Natanz Uranium Enrichment Facility
Indonesia	**~18%**	Collateral spread via USB trade routes
India	~8%	Industrial supply chain overlap with Iranian contractors
Azerbaijan	~3%	Regional geographic proximity to Iran
Others (Global)	~11%	Unintended global spread via USB and network shares

Table 9: Stuxnet Global Infection Distribution

3.6 Source 5: CISA ICS-CERT Advisory ICSA-10-272-01

The Cybersecurity and Infrastructure Security Agency (CISA) issued the primary Stuxnet advisory (ICSA-10-272-01) documenting affected systems and official mitigation steps for operators of ICS/SCADA environments. This advisory remains the authoritative reference for remediation procedures [9].

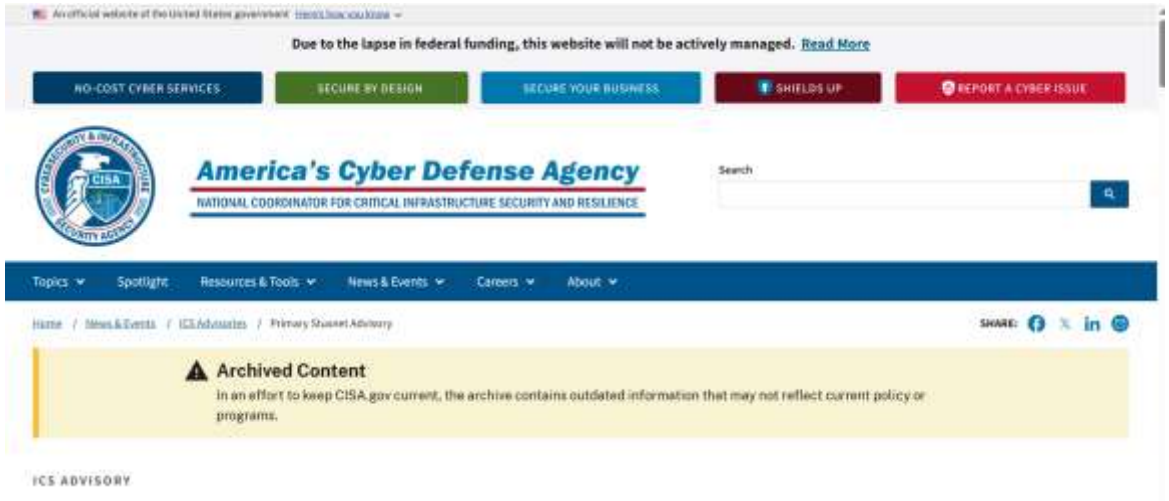

Figure 7: CISA ICS-CERT Advisory ICSA-10-272-01 – Official Stuxnet mitigation guidance

Primary Stuxnet Advisory

Last Revised: September 06, 2018 **Alert Code:** ICSA-10-272-01

OVERVIEW

ICS-CERT has been actively investigating and reporting on the Stuxnet vulnerability. To date, ICS-CERT has released ICSA-10-201-01 - Malware Targeting Siemens Control Software (including Updates B & C) and ICSA-10-238-01 - Stuxnet Mitigations (including Update B).

Stuxnet uses four zero-day exploits (two of which have been patched) and takes advantage of a vulnerability also exploited by Conficker, which has been documented in Microsoft Security Bulletin MS-08-067.Microsoft Security Bulletin, http://www.microsoft.com/technet/security/bulletin/ms08-067.mspx, website last accessed September 28, 2010. The known methods of propagation include infected USB devices, network shares, STEP 7 Project files, WinCC database files, and the print spooler vulnerability addressed by MS-10-061.Microsoft Security Bulletin,

Figure 8: Affected Siemens product versions documented in CISA advisory

3.6.1 Affected Siemens Product Versions

Product	Affected Versions	Fixed Version
SIMATIC WinCC	Older than V7.0 SP2 Update 1	V7.0.2.1 and later
SIMATIC STEP 7	Prior to V5.5 SP1	V5.5.1 and later
SIMATIC PCS 7	All versions using above software	Apply associated patches
Siemens S7-315 PLC	Hardware targeted – all firmware versions	Firmware verification required
Siemens S7-417 PLC	Hardware targeted – all firmware versions	Firmware verification required

Table 10: Affected Siemens Product Versions (CISA ICSA-10-272-01)

3.7 Source 6: Academic Literature

Several peer-reviewed and conference papers provide additional analytical depth on the Stuxnet operation, supplementing primary technical sources with strategic and policy-level analysis [10][11][12].

Paper	Authors	Year	Key Contribution
Stuxnet: Dissecting a Cyberwarfare Weapon	Langner, R.	2011	First technical PLC analysis – IEEE Security & Privacy
W32.Stuxnet Dossier v1.4	Falliere, Murchu, Chien	2011	Most comprehensive 69-page technical report
Stuxnet and the Limits of Cyber Warfare	Lindsay, J.	2013	Political and strategic impact analysis
An Analysis of the Stuxnet Worm	Chen, T.	2010	Early academic analysis – ISCIS Conference

Table 11: Academic Literature Sources

4. Step 2 – Threat Intelligence Extraction

Following the structured CTI methodology, raw research is distilled into actionable intelligence by answering seven core questions. This intelligence extraction process transforms descriptive information into structured data ready for STIX mapping [3][5].

CTI Question	Intelligence Answer
Who did it? (Threat Actor)	Equation Group – attributed to NSA/TAO and Israeli Unit 8200. Codenames: Operation Olympic Games (US/Israel joint op) and GOSSIP GIRL (4-actor collaboration). Confirmed by Kaspersky Lab (2015) through shared zero-day exploit analysis with Fanny worm [8].
What malware? (Malware Object)	W32.Stuxnet – a combined Worm, Windows Rootkit, and PLC Cyberweapon. MITRE Software ID: S0603. First seen June 17, 2010. Infected ~100,000 systems globally; 60% in Iran [1][2].
How did it get in? (Attack Patterns)	(1) USB .LNK autorun – air-gap crossing via CVE-2010-2568; (2) Print Spooler RPC over LAN via CVE-2010-2729; (3) Network shares via MS08-067; (4) Siemens STEP 7 project file infection; (5) Peer-to-peer self-update mechanism [2][9].
What vulnerabilities? (CVEs)	CVE-2010-2568 (CVSS 9.3 Critical), CVE-2010-2772 (CVSS 7.2 High), CVE-2010-2729 (CVSS 9.3 Critical), CVE-2010-3338 (CVSS 7.2 High). Four simultaneous zero-days – a world record at the time of deployment [7].
Who was targeted? (Identity)	Natanz Uranium Enrichment Facility, operated by the Atomic Energy Organization of Iran (AEOI). Specifically targeted Siemens S7-315 and S7-417 PLCs controlling IR-1 uranium enrichment centrifuges [9].
Signs of infection? (IOCs)	Files: ~WTR4132.tmp, ~WTR4141.tmp, mrxcls.sys, mrxnet.sys, oem7a.PNF, mdmcpq3.PNF, mdmeric3.PNF. Registry: HKLM\...\Services\MRxCls, HKLM\...\Services\MRxNet. Injected processes: svchost.exe, services.exe, lsass.exe [2].
How to stop it? (Courses of Action)	Apply MS10-046, MS10-061, MS10-092 patches; run Siemens SysClean tool; upgrade WinCC to V7.0.2.1+ and STEP 7 to V5.5.1+; disable AutoRun/AutoPlay; restrict USB access; implement IT/OT network segmentation using the Purdue Reference Model [9].

Table 12: Structured CTI Extraction – Seven Core Intelligence Questions

5. Step 3 – STIX 2.1 Object Mapping

STIX (Structured Threat Information eXpression) version 2.1 is an open standard maintained by OASIS for representing and sharing cyber threat intelligence. Every piece of extracted intelligence is formally mapped to a STIX 2.1 Domain Object (SDO) or Relationship Object (SRO). This section documents the complete object registry for the Stuxnet intelligence bundle [5].

5.1 STIX Object Registry Overview

STIX Type	Count	Description
threat-actor	**1**	Equation Group – NSA/TAO + Israeli Unit 8200 (GOSSIP GIRL umbrella)
malware	**1**	W32.Stuxnet – Worm + Rootkit + ICS Cyberweapon (MITRE S0603)
attack-pattern	**5**	T1091 USB, T1014 Rootkit, T1553 Code Signing, T1195 Supply Chain, Network Propagation
vulnerability	**4**	CVE-2010-2568 (9.3), CVE-2010-2772 (7.2), CVE-2010-2729 (9.3), CVE-2010-3338 (7.2)
identity	**1**	Natanz Uranium Enrichment Facility – AEOI, Iran
indicator	**7**	2 USB files, 2 kernel drivers, 1 payload DLL, 2 registry persistence keys
course-of-action	**6**	3 MS patches (Critical/High), Siemens SysClean, USB controls, IT/OT segmentation
relationship (SRO)	**18**	uses, exploits, targets, indicates, mitigates – connecting all SDOs into a graph

Table 13: STIX 2.1 Complete Object Registry

5.2 Threat Actor SDO

The threat-actor SDO represents the adversary responsible for planning, developing, and deploying Stuxnet. Nation-state attribution at this level of confidence is rare and was established through forensic code analysis, shared exploit timelines, and multiple independent research organizations [1][8].

SDO Field	Value
type	threat-actor
name	Equation Group (NSA/TAO + Israeli Unit 8200)
aliases	GOSSIP GIRL · Operation Olympic Games · NSA TAO
threat_actor_types	nation-state
sophistication	strategic (highest level)
resource_level	government
primary_motivation	ideology – sabotage of Iran's uranium enrichment capability
goals	Destroy Natanz IR-1 centrifuges; delay Iranian nuclear weapons capability by ~2 years

Table 14: Threat Actor SDO – Equation Group

5.3 Malware SDO

The malware SDO represents W32.Stuxnet itself. Stuxnet is classified as a multi-type malware combining the characteristics of a network worm, a Windows rootkit, and a specialized PLC cyberweapon the first of its kind ever discovered in the wild [2][4].

SDO Field	Value
type	malware
name	Stuxnet (W32.Stuxnet)
malware_types	worm · rootkit · trojan
first_seen	2010-06-17 (discovered by VirusBlokAda / Sergey Ulasen, Belarus)
platforms	Windows XP, Vista, 7; ICS/SCADA – Siemens WinCC, STEP 7, S7-315/417 PLCs
capabilities	hides-artifacts, infects-remote-machines, persists-after-reboot, escalates-privileges, evades-av, violates-system-operational-integrity
PLC payload	OB1/OB35 injection – centrifuge speed cycled between 2 Hz and 1,410 Hz (normal: ~1,000 Hz)
scale	~100,000+ computers infected; 60% in Iran; ~1,000 centrifuges physically destroyed

Table 15: Malware SDO – W32.Stuxnet

5.4 Attack Pattern SDOs (TTPs)

Attack patterns in STIX 2.1 represent the specific tactics, techniques, and procedures (TTPs) used by the adversary. Each attack pattern maps to a MITRE ATT&CK technique and describes how Stuxnet achieved its objectives across different phases of the cyber kill chain [6].

Figure 9: MITRE ATT&CK TTP mapping for Stuxnet (T1091 – Replication Through Removable Media)

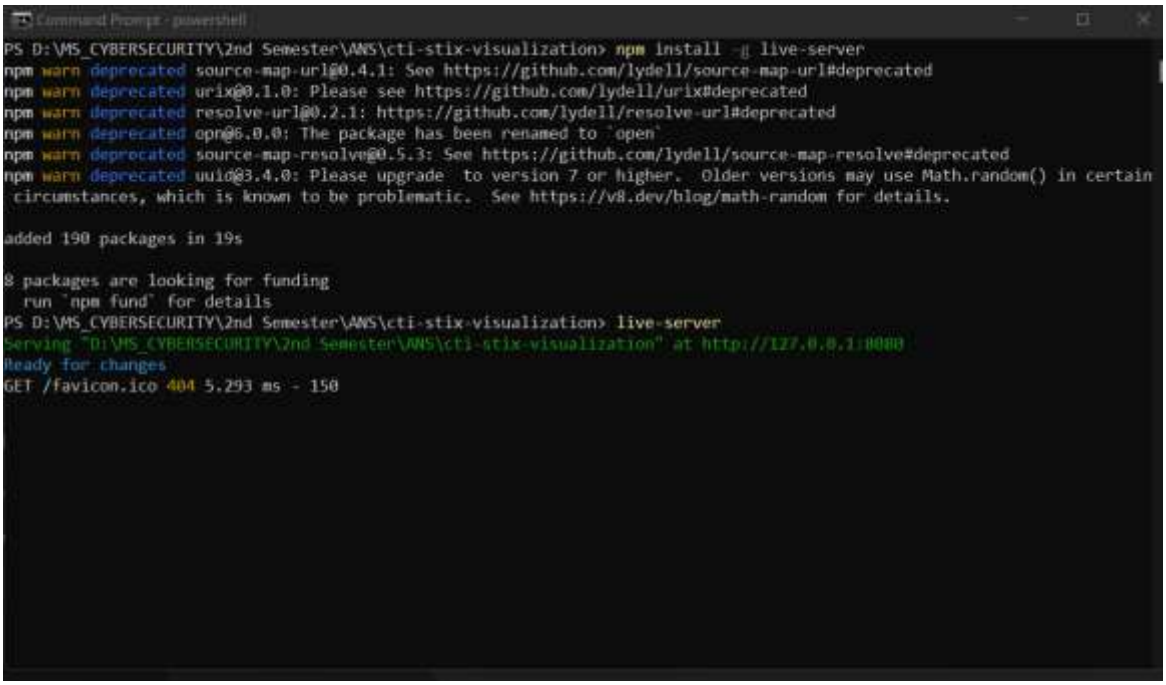

Figure 10: ATT&CK technique T1014 (Rootkit) and T1553 (Subvert Trust Controls) details

MITRE ID	Name	Kill Chain Phase	Description
T1091	**USB Replication**	Initial Access / Lateral Movement	Malicious .LNK files auto-execute on USB insertion via CVE-2010-2568. Primary air-gap crossing mechanism into Natanz. Dropper: ~WTR4132.tmp; USB rootkit: ~WTR4141.tmp.
T1014	**Rootkit**	Defense Evasion / Persistence	Windows kernel rootkit (mrxcls.sys, mrxnet.sys) and PLC rootkit. Injected into svchost.exe, services.exe, lsass.exe. OB1/OB35 PLC injection hides centrifuge speed changes from SCADA operators.
T1553	**Code Signing Bypass**	Defense Evasion	Kernel drivers signed with stolen certificates from Realtek Semiconductor Corp and JMicron Technology Corp. Bypassed Windows Vista/7 unsigned driver enforcement. Both certificates subsequently revoked by VeriSign.
T1195	**Supply Chain Compromise**	Initial Access	Infected Siemens STEP 7 project files to spread engineer-to-engineer across air-gapped networks. Also exploited WinCC hardcoded SQL database password (CVE-2010-2772) to access PLC programming data.
Custom	**Network Propagation (Print Spooler)**	Lateral Movement	Spread across LAN using CVE-2010-2729 (crafted RPC print request, no authentication required). Also used MS08-067 to copy itself as DEFRAG[random].tmp via Windows network shares.

Table 16: Attack Pattern SDOs – Stuxnet TTPs Mapped to MITRE ATT&CK

5.5 Vulnerability SDOs

Vulnerability SDOs in STIX 2.1 correspond to specific CVE entries from the National Vulnerability Database. Stuxnet's simultaneous exploitation of four zero-day vulnerabilities was unprecedented and demonstrated an exceptionally well-funded and sophisticated threat actor [7].

Figure 11: NVD detail page for CVE-2010-2568 (Windows Shell LNK, CVSS 9.3 Critical)

Figure 12: NVD detail page for CVE-2010-2729 (Print Spooler RCE, CVSS 9.3 Critical)

Figure 13: NVD detail page for CVE-2010-3338 (Task Scheduler LPE, CVSS 7.2 High)

5.6 Indicator SDOs (IOCs)

Indicator SDOs provide machine-readable detection patterns (STIX patterns) that can be directly ingested by security tools including SIEM platforms, endpoint detection and response (EDR) systems, and threat intelligence platforms. Each indicator pattern links back to the Stuxnet malware through relationship objects [2].

IOC Type	Name / Value	Location	STIX Pattern
File	~WTR4132.tmp	USB drive root	*[file:name = '~WTR4132.tmp']*
File	~WTR4141.tmp	USB drive root	*[file:name = '~WTR4141.tmp']*
Driver	mrxcls.sys	C:\Windows\System32\Drivers\	*[file:name = 'mrxcls.sys']*
Driver	mrxnet.sys	C:\Windows\System32\Drivers\	*[file:name = 'mrxnet.sys']*
File	oem7a.PNF	C:\Windows\inf\	*[file:name = 'oem7a.PNF']*
Registry	MRxCls service	HKLM\...\Services\MRxCls	*[windows-registry-key:key = 'HKLM\\...\\MRxCls']*
Registry	MRxNet service	HKLM\...\Services\MRxNet	*[windows-registry-key:key = 'HKLM\\...\\MRxNet']*

Table 17: Indicator SDOs – Stuxnet IOCs with STIX Patterns

5.7 Course of Action SDOs

Course of Action (CoA) SDOs document the specific defensive measures recommended to detect, contain, and remediate the Stuxnet threat. These are sourced primarily from CISA advisory ICSA-10-272-01 and aligned with the Microsoft Security Bulletins [9].

Figure 14: Siemens SysClean tool – official remediation tool referenced in CISA advisory

Priority	Action	Description
CRITICAL	Apply MS10-046 – Patch CVE-2010-2568	Apply KB2286198 to all Windows systems. Eliminates the .LNK auto-execution vulnerability that served as Stuxnet's primary USB air-gap crossing mechanism. Patched August 2, 2010.
CRITICAL	Apply MS10-061 – Patch CVE-2010-2729	Patch the Print Spooler RCE vulnerability to block Stuxnet's LAN-based lateral movement. EPSS score of 97.08% indicates near-certain exploitation without patching. Patched September 14, 2010.
HIGH	Apply MS10-092 – Patch CVE-2010-3338	Apply KB2305420 to patch the Task Scheduler privilege escalation vulnerability. Prevents Stuxnet from elevating from user-level to full SYSTEM-level control. Patched December 14, 2010.
CRITICAL	Run Siemens SysClean + SIMATIC Update	Execute the Siemens SysClean removal tool on all WinCC and PCS 7 systems. Upgrade SIMATIC WinCC to V7.0 SP2 Update 1 (V7.0.2.1) or later. Upgrade SIMATIC STEP 7 to V5.5 SP1 or later. Per CISA ICSA-10-272-01.
CRITICAL	Disable AutoRun + Restrict USB Access	Disable Windows AutoRun and AutoPlay features on all endpoints, particularly ICS/OT systems. Implement USB device whitelisting policies. Restrict physical USB port access on PLC workstations and SCADA systems.
HIGH	IT/OT Network Segmentation – Purdue Model	Segment IT and OT networks using the Purdue Reference Model for Industrial Control Systems. Implement strict

		firewall rules between network zones. Air-gap critical PLC systems wherever operationally feasible.

Table 18: Course of Action SDOs – Stuxnet Mitigation Measures

6. STIX 2.1 Relationship Objects (SROs)

STIX Relationship Objects (SROs) connect the intelligence Domain Objects (SDOs) into a meaningful knowledge graph. The 18 SROs in this bundle use five relationship verbs uses, exploits, targets, indicates, and mitigates to represent how all components of the Stuxnet attack are interconnected [5].

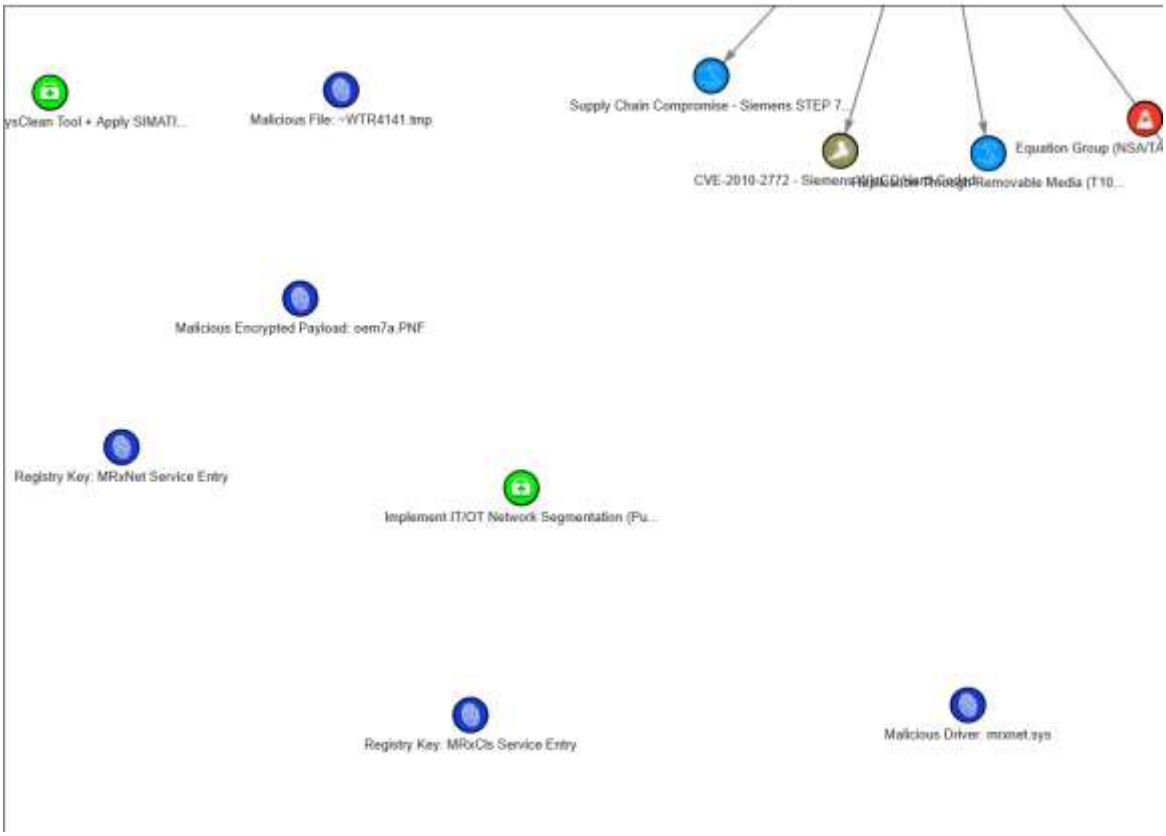

Figure 15: STIX 2.1 Relationship Object mapping for Stuxnet intelligence bundle

Relationship Type	Source Object	Target Object
uses	Equation Group (threat-actor)	Stuxnet (malware) – developed and deployed as part of Operation Olympic Games
uses	Stuxnet (malware)	T1091 USB Replication (attack-pattern) – primary air-gap crossing and propagation method
uses	Stuxnet (malware)	T1014 Rootkit (attack-pattern) – kernel and PLC rootkit for stealth and sabotage
uses	Stuxnet (malware)	T1553 Code Signing (attack-pattern) – stolen Realtek and JMicron certificates
uses	Stuxnet (malware)	T1195 Supply Chain (attack-pattern) – STEP 7 project file infection and WinCC DB exploit
uses	Stuxnet (malware)	Network Propagation (attack-pattern) – Print Spooler RPC and MS08-067 network shares

exploits	Stuxnet (malware)	CVE-2010-2568 (vulnerability) – LNK shortcut zero-day, CVSS 9.3
exploits	Stuxnet (malware)	CVE-2010-2772 (vulnerability) – Siemens WinCC hardcoded password, CVSS 7.2
exploits	Stuxnet (malware)	CVE-2010-2729 (vulnerability) – Print Spooler RCE, CVSS 9.3
exploits	Stuxnet (malware)	CVE-2010-3338 (vulnerability) – Task Scheduler privilege escalation, CVSS 7.2
targets	Equation Group (threat-actor)	Natanz / AEOI (identity) – Operation Olympic Games sabotage campaign
indicates	~WTR4132.tmp (indicator)	Stuxnet (malware) – presence of USB dropper file signals active Stuxnet infection
indicates	mrxcls.sys (indicator)	Stuxnet (malware) – kernel driver presence indicates active rootkit installation
mitigates	MS10-046 patch (course-of-action)	CVE-2010-2568 (vulnerability) – eliminates LNK auto-execute air-gap crossing vector
mitigates	MS10-061 patch (course-of-action)	CVE-2010-2729 (vulnerability) – blocks network RPC lateral movement propagation
mitigates	MS10-092 patch (course-of-action)	CVE-2010-3338 (vulnerability) – prevents privilege escalation to SYSTEM level
mitigates	Disable AutoRun (course-of-action)	Stuxnet (malware) – removes USB replication as the primary entry point
mitigates	Siemens SysClean (course-of-action)	CVE-2010-2772 (vulnerability) – removes malware components and secures WinCC SQL database

Table 19: Complete STIX 2.1 Relationship Objects (18 SROs)

7. Step 4 – STIX JSON Bundle and Visualization

7.1 STIX 2.1 JSON Bundle

The STIX 2.1 structured threat intelligence data was compiled into a formal JSON bundle named stuxnet-intel.json. This machine-readable bundle contains all 42 STIX objects organized according to the STIX 2.1 specification maintained by OASIS. The bundle enables automated ingestion by threat intelligence platforms, SIEM systems, and endpoint detection tools [5].

The bundle provides a complete representation of the full Stuxnet attack lifecycle, including the threat actor, malware characteristics, attack patterns mapped to MITRE ATT&CK, CVE-based vulnerabilities, target system identity, IOC detection patterns, mitigation courses of action, and all 18 directional relationship objects connecting these components.

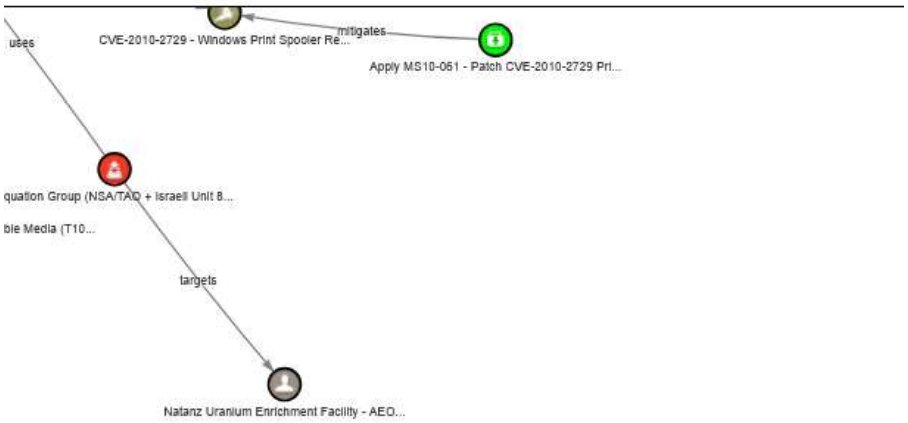

Figure 16: STIX 2.1 JSON bundle object type distribution

7.2 STIX Relationship Graph Visualization

The STIX Viz tool was used to generate a visual graph representation of the complete STIX bundle. Each node in the graph represents a STIX Domain Object, color-coded by type, and each directed edge represents a Relationship Object (SRO). This visualization makes the complex relationships between threat actors, malware, vulnerabilities, indicators, and mitigations immediately comprehensible to analysts [5].

Node color legend:

- Purple – threat-actor (Equation Group)
- Red – malware (W32.Stuxnet)
- Coral/Orange – attack-pattern (5 MITRE TTPs)
- Amber/Yellow – vulnerability (4 CVEs)
- Teal – identity (Natanz / AEOI)
- Blue – indicator (7 IOCs)
- Green – course-of-action (6 mitigations)

STIX Viz Visualization Screenshots:

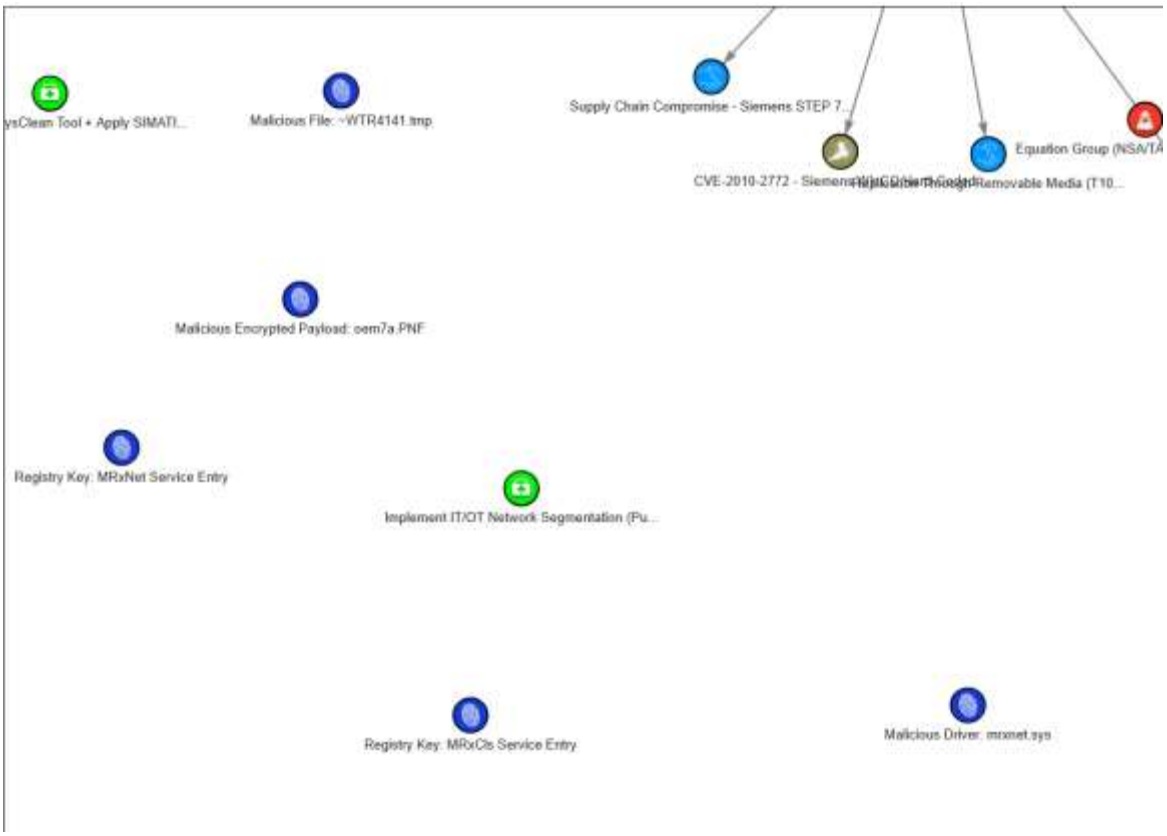

Figure 17: STIX Viz – Full relationship graph of the Stuxnet intelligence bundle (42 objects, 18 relationships)

8. Conclusions

This report has demonstrated a complete end-to-end Cyber Threat Intelligence workflow applied to one of the most significant cyber attacks in history. The analysis of Stuxnet through the STIX 2.1 framework yielded 42 structured intelligence objects spanning eight object types and 18 directional relationship objects.

The key findings of this analysis can be summarized as follows. First, Stuxnet represented an unprecedented convergence of sophisticated cyber capabilities four simultaneous zero-day exploits, stolen digital certificates, a Windows kernel rootkit, and the world's first PLC cyberweapon indicating nation-state-level resources, planning, and intelligence access. Second, the malware's ability to cross air-gapped networks through USB propagation and then spread via LAN-based mechanisms demonstrated a multi-layered attack strategy designed to ensure target penetration regardless of network isolation [1][2].

Third, the STIX 2.1 framework proved highly effective for organizing and representing this complex, multi-faceted threat. The structured format enables intelligence sharing, automated detection rule generation, and integration with existing security toolchains. Fourth, the CISA-recommended mitigations patch application, USB controls, and IT/OT network segmentation remain relevant guidance for ICS/SCADA operators and industrial cybersecurity practitioners today [9].

The long-term legacy of Stuxnet extends beyond its immediate impact on the Iranian nuclear program. It established a precedent for state-sponsored cyber operations targeting critical infrastructure and catalyzed significant investment in ICS/SCADA security research, standards development, and defensive tooling across the global cybersecurity community [10][11].

9. References

All references are formatted in IEEE citation style.

[1] MITRE ATT&CK, "Stuxnet, Software S0603," MITRE Corporation, 2021. [Online]. Available: https://attack.mitre.org/software/S0603/. [Accessed: Apr. 2025].

[2] N. Falliere, L. O. Murchu, and E. Chien, "W32.Stuxnet Dossier, Version 1.4," Symantec Security Response, Feb. 2011. [Online]. Available: https://nsarchive2.gwu.edu/NSAEBB/NSAEBB424/docs/Cyber-044.pdf. [Accessed: Apr. 2025].

[3] National Institute of Standards and Technology (NIST), "Guide to Cyber Threat Information Sharing," NIST Special Publication 800-150, Oct. 2016.

[4] T. Chen, "Stuxnet, the Real Start of Cyber Warfare?," IEEE Network, vol. 24, no. 6, pp. 2–3, Nov./Dec. 2010.

[5] OASIS Cyber Threat Intelligence (CTI) TC, "STIX Version 2.1, Committee Specification," OASIS Standard, Jun. 2021. [Online]. Available: https://docs.oasis-open.org/cti/stix/v2.1/. [Accessed: Apr. 2025].

[6] MITRE Corporation, "ATT&CK for Industrial Control Systems," MITRE ATT&CK, 2021. [Online]. Available: https://attack.mitre.org/matrices/ics/. [Accessed: Apr. 2025].

[7] National Institute of Standards and Technology, "National Vulnerability Database (NVD)," NIST. [Online]. Available: https://nvd.nist.gov. [Accessed: Apr. 2025]. (CVEs: CVE-2010-2568, CVE-2010-2772, CVE-2010-2729, CVE-2010-3338).

[8] Kaspersky Lab, "Equation Group: Questions and Answers," Kaspersky Lab Global Research and Analysis Team (GReAT), Feb. 2015. [Online]. Available: https://securelist.com/equation-group-questions-and-answers/. [Accessed: Apr. 2025].

[9] Cybersecurity and Infrastructure Security Agency (CISA), "ICS-CERT Advisory ICSA-10-272-01: Siemens WinCC and PCS 7 SCADA System," U.S. Department of Homeland Security, Sep. 2010. [Online]. Available: https://www.cisa.gov/news-events/ics-advisories/icsa-10-272-01. [Accessed: Apr. 2025].

[10] R. Langner, "Stuxnet: Dissecting a Cyberwarfare Weapon," IEEE Security & Privacy, vol. 9, no. 3, pp. 49–51, May–Jun. 2011.

[11] J. R. Lindsay, "Stuxnet and the Limits of Cyber Warfare," Security Studies, vol. 22, no. 3, pp. 365–404, 2013.

[12] R. Langner, "To Kill a Centrifuge: A Technical Analysis of What Stuxnet's Creators Tried to Achieve," The Langner Group, Nov. 2013.

Appendix A – Research Collection Sheet

The following research collection sheet summarizes all key intelligence gathered during Step 1, serving as the raw data foundation for the STIX mapping performed in Step 3.

Intelligence Field	Extracted Value
Attack Name	Stuxnet (W32.Stuxnet) – MITRE S0603
First Seen	June 17, 2010
Discovered By	VirusBlokAda – Sergey Ulasen (Belarus)
Threat Actor	Equation Group (NSA/TAO + Israeli Unit 8200)
Codename	Operation Olympic Games / GOSSIP GIRL
Motivation	Sabotage Iran's uranium enrichment program at Natanz
Target	Natanz Enrichment Facility, AEOI, Iran
Target System	Siemens S7-315 / S7-417 PLCs
CVEs Used	CVE-2010-2568 (9.3 Critical), CVE-2010-2772 (7.2 High), CVE-2010-2729 (9.3 Critical), CVE-2010-3338 (7.2 High)
Files Dropped	~WTR4132.tmp, ~WTR4141.tmp, mrxcls.sys, mrxnet.sys, oem7a.PNF, mdmcpq3.PNF, mdmeric3.PNF, oem6c.PNF
Registry Keys	HKLM\...\Services\MRxCls; HKLM\...\Services\MRxNet
Injected Processes	svchost.exe, services.exe, lsass.exe
Propagation Methods	USB (.LNK autorun), Network Shares (MS08-067), Print Spooler (CVE-2010-2729), STEP 7 project files, P2P self-update
Certificates Stolen	Realtek Semiconductor Corp (revoked), JMicron Technology Corp (revoked)
Damage	~1,000 centrifuges destroyed; Iran nuclear program delayed ~2 years
Sources Verified	MITRE ATT&CK, NVD/NIST, Symantec Dossier v1.4, Kaspersky Securelist, CISA ICSA-10-272-01, Academic literature (Langner, Chen, Lindsay)

Table A-1: Complete Stuxnet Research Collection Sheet